

DATA PROCESSING ADDENDUM

to the Pharma Logistics Services Agreement between Helvetia Pharma Logistik GmbH and Korvane Cold Chain Sp. z o.o. — Helvetia contract ref. HPL-LV-2016-0418 — Korvane ref. KCC/DPA/2023/003

Version 4 — signed copy, with annexes I to V and the change log of 11 March 2024 appended — printed from the contract register, so page numbers may not match the signed paper

Prepared on the Controller's template (Brandt Seidenstücker Rechtsanwälte, Freiburg im Breisgau), as negotiated with Korvane Legal. Korvane's manuscript remarks are shown as [SB: ...] and are not part of the instrument.

Preamble

This Data Processing Addendum (the "DPA") is made on 17 January 2023 and takes effect on 1 February 2023 (the "DPA Effective Date") between Helvetia Pharma Logistik GmbH, Heinrich-Kümmell-Weg 41, 79098 Freiburg im Breisgau, Germany, entered in the commercial register of the local court of Freiburg under HRB 712364 (the "Controller"), and Korvane Cold Chain Sp. z o.o., ul. Łużycka 14, 81-537 Gdynia, Poland, KRS 0000488213 (the "Processor"). It forms part of, and is subject to, the Pharma Logistics Services Agreement of 14 September 2016 between the same parties as amended to date (the "Services Agreement"), under which the Processor transports temperature-sensitive pharmaceutical consignments for the Controller in reefer containers and monitors them with KC-Tag 4 loggers through the Tidewalk platform.

Whereas the parties acknowledge that in the course of those services the Processor handles certain personal data on behalf of the Controller, they have agreed as follows in order to meet the requirements of Article 28 of Regulation (EU) 2016/679 (the "GDPR") and, where applicable, the Polish Act on the Protection of Personal Data of 2018.

1. Subject matter, nature and duration of the processing

1.1 The subject matter of the processing is the personal data contained in the transport, monitoring and proof-of-delivery records the Processor creates or receives when performing the Services Agreement. The nature and purpose of the processing, the types of personal data and the categories of data subjects are set out in Annex I. The processing lasts for the term of the Services Agreement and, thereafter, until the personal data have been returned or deleted under clause 11.

1.2 The parties note that readings from the KC-Tag 4 loggers (temperature, humidity, door-open events) are, by themselves, technical data and not personal data. They become personal data only when, in the Processor's systems, they are linked to an identified or identifiable driver, consignee employee or other natural person, and the retention rules for personal data in Annex IV apply to the logger readings only in that case. For the avoidance of doubt, the retention period of 60 months for GDP documentation in Annex IV applies in any case, as a documentary rather than a data-protection obligation.

1.3 The Processor shall process the personal data only on the documented instructions of the Controller, including with regard to transfers to a third country, unless required to do so by Union or Member State law to which it is subject; in such a case the Processor shall inform the Controller of that legal requirement before processing, unless the law prohibits such information. The Services Agreement, this DPA and the Controller's instructions given through the Tidewalk customer portal constitute the Controller's complete documented instructions on the DPA Effective Date. The Processor shall inform the Controller without delay, and in any event within 5 Business Days, if it considers that an instruction infringes the GDPR.

2. Confidentiality and personnel

2.1 The Processor shall ensure that persons authorised to process the personal data have committed themselves to confidentiality in writing or are under an appropriate statutory obligation of confidentiality. This undertaking continues after the end of their employment.

2.2 Access to the Controller's personal data within the Processor's organisation is limited to the following roles: dispatchers at GDY-1, HAM-2, RTM-3 and GOT-4; the Key Account Manager responsible for the Controller; the Quality and Compliance Manager; the Tidewalk application support team; and the Legal Counsel in the case of a data protection incident. The Processor shall review the list of named individuals holding these roles at least every 90 days and shall remove access that is no longer needed within 2 Business Days.

2.3 [SB: The Controller originally wanted access limited to named individuals, and a list of those names sent to them every quarter. I got that down to roles, plus the 90-day review, because the night shift ("the owls") rotates too often for a names list to be accurate for more than a fortnight. They accepted provided the review is documented. It is documented in the access review sheet kept by Kamil Zdunek.]

3. Security of processing

3.1 Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing, the Processor shall implement the technical and organisational measures set out in Annex II and shall maintain them throughout the term. The Processor may update the measures provided that the overall level of security is not reduced and the Controller is informed of material changes at the next quarterly review.

3.2 The Processor shall maintain for the Tidewalk platform a certificate of conformity with ISO/IEC 27001. At the DPA Effective Date the certificate in force was issued on 15 March 2022 and is valid until 14 March 2025. The Processor shall notify the Controller within 10 Business Days if the certification is suspended or withdrawn.

3.3 The Processor shall carry out an independent penetration test of Tidewalk and of the Tidewalk API at least once in every 12 months, and shall give the Controller on request a management summary of the findings of the most recent test within 20 Business Days. Findings classed as critical shall be remedied within 14 days, and findings classed as high within 45 days.

4. Sub-processors

4.1 The Controller gives the Processor a general authorisation to engage sub-processors, subject to this clause 4. The sub-processors authorised at the DPA Effective Date are listed in Annex III together with the processing each carries out and the place where it is carried out.

4.2 The Processor shall inform the Controller of any intended addition or replacement of a sub-processor at least 30 days before the change takes effect, by e-mail to the Controller's data protection contact in Annex V and by notice on the Tidewalk status page. The Controller may object on reasonable data protection grounds within 14 days after the notice. If the objection is not resolved within a further 30 days, the Controller may terminate the affected services on 60 days' notice, without penalty, and the Processor shall refund any prepaid fees for the period after termination.

4.3 The Processor shall bind every sub-processor by a written contract imposing on it the same data protection obligations as those in this DPA, and shall remain fully liable to the Controller for the performance of the sub-processor's obligations. The Processor shall on request provide a copy of the relevant data protection provisions of any sub-processor contract, with commercial terms redacted, within 10 Business Days.

4.4 In an emergency (for example, the insolvency of a sub-processor or an incident that makes its service unavailable), the Processor may replace a sub-processor on shorter notice, but not on less than 5 Business Days' notice

where this is practicable, and the Controller keeps its right to object after the event.

5. International transfers

5.1 The Processor shall not transfer the personal data outside the European Economic Area, and shall not allow a sub-processor to do so, except (a) to a country that benefits from an adequacy decision of the European Commission, or (b) subject to the standard contractual clauses adopted by Commission Implementing Decision (EU) 2021/914, Module Two (controller to processor) or Module Three (processor to processor), which the parties incorporate by reference where relevant, with the Processor's Polish supervisory authority named as the competent authority and German law as the governing law of the clauses.

5.2 At the DPA Effective Date the only processing outside the EEA is the support-ticket service in the United Kingdom, which relies on the adequacy decision for the United Kingdom. If that decision ceases to apply, the Processor shall within 30 days either move the service into the EEA or put in place the clauses referred to in 5.1(b).

6. Assistance and data subject requests

6.1 Taking into account the nature of the processing, the Processor shall assist the Controller by appropriate technical and organisational measures in responding to requests from data subjects. If a data subject makes a request directly to the Processor, the Processor shall pass it to the Controller within 3 Business Days and shall not respond itself except to acknowledge receipt, unless the Controller asks it to.

6.2 The Processor shall provide reasonable assistance with data protection impact assessments and prior consultations. Assistance of up to 16 person-hours in any Contract Year is included in the fees; further assistance is charged at EUR 118 per hour.

6.3 The Processor shall respond to a request by the Controller for the export of the personal data concerning a particular data subject within 10 Business Days, in CSV format.

6A. Records, training and cooperation with authorities

6A.1 The Processor shall maintain a record of the processing activities carried out on behalf of the Controller, as required by Article 30(2) GDPR, and shall provide an extract relating to the Controller within 15 Business Days of request. The record shall be reviewed by the Legal Counsel at least twice a year, in March and in September.

6A.2 The Processor shall ensure that every employee with access to the Controller's personal data completes data protection training within 30 days after joining and then once in every calendar year, and shall keep attendance records for 3 years. Dispatchers on the night shift complete the same training; if an employee is on extended leave at the time of the annual training, it shall be completed within 30 days after return.

6A.3 If a supervisory authority contacts the Processor about the Controller's personal data, the Processor shall inform the Controller within 2 Business Days, unless prohibited by law, and shall not disclose the Controller's data to the authority without the Controller's consent, except where the law requires it.

6A.4 The Processor shall not use the Controller's personal data to build profiles, to train or improve any machine learning model, or for marketing, and shall not combine it with personal data of other customers. [SB: this clause was added by Helvetia's counsel late in the negotiation, when the question of "analytics on dwell times" came up. We told them Tidewalk's dwell-time report works on container records and not on named persons, which is true, and they let the clause stand as drafted.]

6A.5 Where the Controller carries out a pharmaceutical recall or a quality hold involving a consignment in the Processor's custody, the Processor shall within 4 hours of the Controller's request, at any time, freeze the deletion of all personal data connected to that consignment until the Controller lifts the hold in writing. The freeze overrides the retention periods in Annex IV for the data concerned.

7. Personal data breach

7.1 The Processor shall notify the Controller of any personal data breach affecting the Controller's personal data without undue delay, and in any event within 30 hours after the Processor becomes aware of it. For this purpose the Processor becomes aware when a member of the security or the legal function of the Processor has reasonable certainty that a breach affecting the Controller's data has occurred. Notification shall be given by telephone to the Controller's data protection officer (the number is in Annex V) and confirmed by e-mail.

7.2 The notification shall, to the extent known at that time, describe the nature of the breach, including the categories and approximate number of data subjects and records concerned; give the name and contact details of the Processor's data protection contact; describe the likely consequences; and describe the measures taken or proposed. If not all information is available, it may be given in phases without further undue delay. The Processor shall in any event provide an interim written update within 72

hours after the first notification, and a final report within 30 days after the breach has been contained.

7.3 The Processor shall take reasonable steps to contain and mitigate the breach, preserve the evidence, and cooperate with the Controller and with the supervisory authority. The Controller decides whether to notify the supervisory authority and the data subjects; the Processor shall not make such a notification itself about the Controller's data unless the law requires it. Costs reasonably incurred by the Controller for notification and credit-monitoring services where the breach was caused by the Processor's failure to comply with this DPA are recoverable within the liability limits in clause 12.

7.4 [SB: The 30-hour figure is a compromise. Helvetia asked for 12 hours, citing their own 72-hour clock under Article 33 and the fact that they need two days to consult their works council. I offered 48. The number 30 was agreed on the call of 9 January 2023 — Benedikta was on the call and confirmed our incident desk can realistically hit it, including weekends. Anything shorter needs a 24/7 legal duty officer, which we do not have.]

8. Audit and inspection

8.1 The Processor shall make available to the Controller all information necessary to demonstrate compliance with Article 28 GDPR and shall allow for and contribute to audits, including inspections, conducted by the Controller or an auditor mandated by it who is bound by confidentiality and is not a competitor of the Processor.

8.2 The Controller may carry out an audit once in every period of 12 months, on not less than 20 Business Days' written notice, lasting not more than 2 working days on site at the Processor's Gdynia premises. The Controller may carry out an additional audit on not less than 5 Business Days' notice after a personal data breach affecting its data or if a supervisory authority requires it.

8.3 The Controller bears its own audit costs. If the audit discloses a material breach of this DPA by the Processor, the Processor shall reimburse the Controller's reasonable external audit costs up to EUR 9,000, and shall remedy the breach within 30 days or within such other period as is agreed in the audit report.

8.4 The Controller acknowledges that Helvetia Pharma Logistik GmbH is itself subject to audits under Good Distribution Practice and agrees that a GDP audit of the Processor's depots may be combined with a data protection audit under this clause, in which case the notice period is that of the GDP audit, if shorter than the one in 8.2, but not shorter than 10 Business Days.

9. Retention and deletion during the term

9.1 The Processor shall retain the categories of personal data listed in Annex IV for the periods stated there and shall delete or anonymise them, in a manner that cannot be reversed, within 30 days after the end of the retention period. Deletion from backups shall be completed by rotation within the backup cycle described in Annex II.

9.2 If a legal obligation to which the Processor is subject requires a longer retention, or if the Controller instructs in writing that data are to be kept longer (for instance because of a pending complaint or recall), the Processor shall retain the data for the period required, and only for that purpose.

9.3 [SB: Annex IV is the part Helvetia's quality people cared about. The 60 months for logger readings is their GDP documentation requirement, written into the quality agreement of 2019; it is not a data-protection requirement in itself. Do not confuse that figure with the 90 days for GPS positions of drivers, which is ours, justified by the works-council agreement at Gdynia and the minimisation principle.]

10. Costs, liability and insurance

10.1 Except as stated in this DPA, each party bears its own costs of performing it.

10.2 The Processor's liability to the Controller for breach of this DPA and of the GDPR, and the Controller's liability to the Processor, shall be subject to the limits of liability in the Services Agreement, except that for claims arising from a personal data breach the Processor's aggregate liability in any Contract Year shall not exceed EUR 2,000,000, which is separate from, and not counted against, the general cap in the Services Agreement.

10.3 The Processor shall maintain cyber and data liability insurance with a cover of not less than EUR 3,000,000 per claim throughout the term, and shall provide a broker's certificate on request within 10 Business Days.

11. Return and deletion on termination

11.1 When the Services Agreement ends, or on the Controller's earlier written instruction, the Processor shall, at the Controller's choice, return all personal data to the Controller in CSV or delete it, and shall delete existing copies, within 45 days. The Processor shall confirm the deletion in writing within 10 Business Days after completing it, in the form of a deletion certificate signed by its data protection contact.

11.2 The Processor may keep personal data only to the extent that Union or Member State law requires, in which case it shall inform the Controller of

the law concerned and the period, shall isolate the data, and shall delete it when that period ends.

11.3 The Processor shall make Tidewalk raw telemetry linked to the Controller's consignments available for download in CSV and PDF for the whole of the period of 45 days referred to in 11.1.

12. General

12.1 In the event of a conflict, the following order of precedence applies: first, the standard contractual clauses where they apply; second, this DPA on data protection matters; third, the Services Agreement.

12.2 This DPA remains in force as long as the Processor processes personal data on behalf of the Controller. It may be amended only in writing, signed by both parties, except for the replacement of the sub-processors under clause 4 and of the details in Annexes II, III and V, which may be made by notice.

12.3 This DPA is governed by German law. The courts at Freiburg im Breisgau shall have non-exclusive jurisdiction, without prejudice to the jurisdiction of the supervisory authorities. The language of this DPA is English; a German courtesy translation exists in the contract file but has no legal effect.

Signed on 17 January 2023 for Helvetia Pharma Logistik GmbH by Dr. Annelie Reutter (Data Protection Officer) and Konstantin Sauer-Wehrle (Head of Quality & Compliance); for Korvane Cold Chain Sp. z o.o. by Marta Kowarzik (Chief Executive Officer) and Sofia Brandão (Legal Counsel, acting under power of attorney no. 4/2021).

Annex I — Details of the processing

The Processor processes personal data to carry out cold-chain transport and monitoring of the Controller's consignments, to raise alerts, to document delivery and chain of custody, to bill the services in ColdLedger, and to provide support. Categories of data subjects: the Controller's employees and contractors who place orders or receive alerts; consignee staff who sign for goods; and the drivers and dispatchers of the Processor and of its subcontracted hauliers. Types of personal data: name, business e-mail and telephone number; signature on the electronic proof of delivery; driver name and vehicle registration number; the GPS position of a tractor unit when linked to a driver; recordings of alert telephone calls. Special categories of personal data are not intended to be processed and the Controller shall not upload them.

Annex II — Technical and organisational measures (summary)

Measure	Specification
Encryption in transit	TLS 1.2 or higher on all Tidewalk and API endpoints
Encryption at rest	AES-256 for databases and file stores
Authentication	Multi-factor authentication mandatory for all staff accounts; customer portal MFA offered, mandatory for Controller administrators
Access logging	Access and admin logs kept for 13 months
Backups	Every 6 hours; each backup kept for 35 days, in a second EEA location
Recovery objectives	Recovery point objective 6 hours; recovery time objective 8 hours
Penetration test	At least once in every 12 months, by an independent firm
Vulnerability patching	Critical within 14 days, high within 45 days
Physical security	Server rooms access-controlled; badge logs kept 12 months

Annex III — Authorised sub-processors (position at 1 February 2023, as updated by notice)

Sub-processor	Processing	Location
---------------	------------	----------

Lintu Cloud Hosting Oy	Hosting of Tidewalk production database and backups	Finland (Tampere and Kajaani data centres)
Nimbus Mail Relay GmbH	Outbound alert and report e-mail relay	Germany (Frankfurt)
Arendal Port Services AB	Gate in/out event data at the Gothenburg-Arendal terminal	Sweden
Kestrel Support Desk Ltd	Customer support ticketing	United Kingdom (adequacy decision)
Brightline Messaging AB	SMS and voice alert delivery (replaced SMSGate Nordic ApS on 15 April 2024)	Sweden

Former sub-processor (removed): SMSGate Nordic ApS, Copenhagen, Denmark, which delivered SMS and voice alerts from 1 February 2023 until 14 April 2024.

Annex IV — Retention periods

Data	Retention
KC-Tag 4 readings linked to a Helvetia consignment (GDP documentation)	60 months from the consignment delivery date
Electronic proof of delivery, incl. signatures	24 months
GPS positions of drivers	90 days
Recordings of alert telephone calls	6 months
Support tickets and attachments	36 months after closure
Access and admin logs	13 months
Backups	35 days
Invoicing data in ColdLedger (legal retention, Polish accounting law)	5 years from the end of the financial year

After the end of the Services Agreement the periods in clause 11 apply instead, subject to clause 11.2.

Annex V — Contacts

Controller: Dr. Annelie Reutter, Data Protection Officer, datenschutz@helvetia-pharma.example, telephone +49 761 555 0127.
Processor: Sofia Brandão, Legal Counsel and data protection contact, dpo@korvane.example, telephone +48 58 555 0160; deputy Benedikta Aaltonen (Quality and Compliance Manager), who answers the incident desk line +48 58 555 0199 outside office hours.

Change log

Date	Change
17 January 2023	Signed, version 4
11 March 2024	Notice under clause 4.2: replacement of SMSGate Nordic ApS by Brightline Messaging AB, effective 15 April 2024. The Controller raised no objection by the deadline of 25 March 2024
2 September 2024	Annex V updated: the incident desk number is now +48 58 555 0199 (previously +48 58 555 0198)